

Brief sécurité — Application Pixel & Pion

Contexte

Ce document décrit les problèmes de sécurité constatés sur l'application de gestion Pixel & Pion (catalogue, emprunts, comptes clients), livrée par un prestataire sans revue de sécurité.

Il décrit des symptômes observés et les risques métier qu'ils font courir à l'entreprise et à ses abonnés. Il ne propose aucune solution technique : le choix de la protection à mettre en œuvre revient à la personne qui reprend la maintenance.

1. Mots de passe stockés en clair

Symptôme constaté : en consultant la table des comptes abonnés en base de données, le mot de passe de chaque abonné apparaît en texte lisible, identique à ce qu'il a saisi à l'inscription. La vérification du mot de passe à la connexion compare directement cette valeur stockée à la saisie de l'utilisateur.

Risque métier : en cas de fuite de la base de données, quelle qu'en soit la cause (sauvegarde mal protégée, accès interne non contrôlé, faille sur un autre composant), l'ensemble des mots de passe des abonnés serait immédiatement exploitable. Beaucoup d'abonnés réutilisent le même mot de passe sur plusieurs services : la fuite ne toucherait pas seulement Pixel & Pion.

Ce point engage la responsabilité de l'entreprise au regard du RGPD, le règlement européen sur la protection des données personnelles, qui impose de protéger les données des utilisateurs par des mesures adaptées à l'état de l'art.

2. Endpoints sensibles accessibles sans authentification

Symptôme constaté : plusieurs endpoints de l'API, en particulier ceux qui exposent le profil d'un abonné et son historique d'emprunts, répondent avec les données demandées sans qu'aucun jeton ni session valide n'ait été présenté. N'importe qui connaissant ou devinant l'URL peut appeler ces endpoints directement, par exemple depuis Swagger UI ou un simple client HTTP.

Risque métier : un tiers extérieur à l'entreprise peut consulter des profils et des historiques d'emprunts sans jamais s'être identifié. Cela expose des informations personnelles des abonnés (coordonnées, habitudes d'emprunt) à quiconque explore l'API, y compris un acteur malveillant automatisant les requêtes.

3. Absence de contrôle d'autorisation entre abonnés

Symptôme constaté : un abonné connecté avec ses propres identifiants peut consulter le profil et l'historique d'emprunts d'un autre abonné, en changeant simplement l'identifiant transmis dans l'URL de la requête. L'application vérifie qu'un utilisateur est connecté, mais ne vérifie jamais que les données demandées lui appartiennent.

Risque métier : chaque abonné peut aujourd'hui consulter les données personnelles de n'importe quel autre abonné du service, du seul fait d'être connecté. C'est le problème le plus immédiat pour Pixel & Pion : il ne nécessite ni piratage ni compétence technique particulière, un abonné ordinaire

peut le déclencher par accident en modifiant une URL.

Ce que ce document ne couvre pas

Ce brief ne décrit pas la protection à mettre en œuvre pour chacun de ces trois problèmes : ni le mécanisme de hachage à utiliser, ni la manière de déclarer l'authentification ou l'autorisation dans l'application. Il se limite au constat et au risque.

Il ne couvre pas non plus les règles métier du catalogue et des emprunts, déjà décrites dans le plan de tests remis séparément.